MASTER PLAN v2.1: GeminiForge documentation workspace (living document)

v1 written 2026-10-21 morning. **v2 rewritten 2026-10-21 after six sourced research passes** (docs/10, 13-18). `[x]` = done and tested, `[~]` = partly, `[ ]` = not started, `[?]` = waiting for the owner. Tags: **Q** = question for the owner (my recommendation given), **D** = decision made, **OWN** = only the owner can do it, **S/M/L** = effort (small: under a day, medium: 1-3 days, large: more), **(docs/N)** = where the evidence is. Facts marked UNVERIFIED in the research docs stay unverified here. Superseded by this file: docs/03-ROADMAP-NEXT.md, docs/ROADMAP.md. Older lists kept for reference: docs/05 (155 ideas), docs/08 (audit).

> **v2.1 (2026-10-22):** audit of the ChatGPT Parts A+B research added (docs/19) and owner decisions D12 (Canvas build dropped), D13 (custom dropdowns stay), D14 (share links are project-wide). Part C security audit (docs/21) and Part E+F operations/email audit (docs/22) added the same day.

> **Budget rule D11: 0 USD.** Anything in older docs that costs money (Anthropic/OpenAI/paid Gemini API, domain, Resend, Supabase/Vercel Pro, OpenRouter credit) is dropped or replaced by a free path.

0. State (v0.7.0)

Live: https://geminiforge-workbench.vercel.app (auto-deploys from `main`). Supabase `plbvgcnyfclillatpowc` (free plan). Tests: qa-ai 152, qa-content 12, prodcheck 101, MCP offline 33, invitation email 9, SQL matrix. Phase 1 and 2 below are done. Checked 2026-10-22: Postgres 17.11, database 15 MB of 500 MB, repo already on Vite 8.3.4 / TypeScript 7.0.2 / React 18.3.1, browser + invite + MCP already use `sb_publishable_/sb_secret_` keys.

1. What the research changed (read this first)

1. **Supabase changes Data API grants on 2026-10-30 (8 days away on 2026-10-22).** New `public` tables will no longer be granted to anon/authenticated/service_role automatically; a migration that creates a table without explicit `GRANT` fails with 42501. Rule from now on: every new table migration contains its GRANTs and RLS in the same file. **Functions too**: Supabase's "Securing your API" page says new functions in `public` are also moving to opt-in (`grant execute` explicitly); what exactly happens to new functions on 10-30 is UNVERIFIED, so grant explicitly either way. (docs/16, docs/19)
2. **Phase order changes.** Verify client compatibility (Claude Code, Cursor, claude.ai, Gemini app) BEFORE building OAuth; header tokens first, path tokens only for the Gemini app, read-only, 24 h by default. (docs/14)
3. **Ask-the-docs must cost 0 (D11, owner 2026-10-21).** The paid Anthropic route from docs/15 is dropped. Free path first: your Google AI Pro Gemini app connected to our MCP (no API key), NotebookLM as a reading aid, and an extractive quote-finder built on Postgres full-text search (verbatim by construction, no model). An in-browser model or a free API tier is optional and decided by research prompt Z1. Key rotation across free accounts stays forbidden (terms). (docs/15, docs/12)
4. **Editor: CodeMirror 6 (Markdown source + preview), not a WYSIWYG editor**; save with a version column and 3-way merge, not a CRDT. (docs/17)
5. **Planning layer: rows are the source of truth, Markdown is rendered; progress is computed, never stored.** (docs/13)
6. **New high-value items from the benchmark**: verified/owner/review-by pages, notification inbox, content-gap list, request-access, share-link hardening. (docs/18)

7. **Survival items on the free plan**: backups do not exist unless we build them (re-verified 2026-10-22 on Supabase's backup page: daily backups only on Pro/Team/Enterprise; a ChatGPT audit claiming otherwise was wrong, docs/19); the project pauses after 7 days of no user database activity (in-database cron may not count); Hobby cron runs once per day. (docs/16)
8. **Corrected assumption**: TOTP two-factor sign-in is free on all Supabase plans (only phone MFA is paid; leaked-password protection is Pro). Earlier notes said "no MFA on free": **Q15**, confirm in the dashboard.
9. **Cut or defer** a long list for a solo owner (section 12).
10. **Audit of the ChatGPT Parts A+B report (docs/19, 2026-10-22):** keep CodeMirror 6, Zustand, hash routing, adjacency list, Postgres full-text search; upgrade to React 19.3.1 after the grants work; do the 10-30 migration first; classify the 28 `SECURITY DEFINER` functions; share links use a `#/s/<secret>` fragment with a hashed secret; native `<dialog>` for true modals; no Biome/Rolldown/Tailwind/ltree/vector.
11. **Audit of the ChatGPT Part C (security/privacy) report (docs/21):** share links become `/share#secret` + explicit click + a server proxy (no anonymous RPC, no share JWT); invite-bound account creation (the app has none today); TOTP + AAL2 inside sensitive RPCs; a real CSP after moving the inline CSS; hardened `api/invite` and `/api/join`; append-only security log; supply-chain rules after the 2025-2026 npm compromises (Shai-Hulud, Axios); full git history checked clean. Two report claims were wrong/unconfirmed: free production deployment protection on Vercel, and the Mammoth 1.12.2/1.12.3 advisories.
12. **Audit of the ChatGPT Part E+F (operations + email) report (docs/22):** keep-alive via two independent daily readers of a one-row table; encrypted nightly dump restored inside the same job, copied to Backblaze B2 and a 14-day artifact; Healthchecks + UptimeRobot; Gmail path kept. Report right on the 1-year pause-restore window (the Supabase MCP docs index is stale at 90 days). Report code has real bugs (weekly test never fires, restore into plain Postgres fails, global npm CLI, `curl | bash`, floating action tags).

PHASE 1: Foundations (DONE)

- [x] 1.1 Reader app, answer engine, notes, backups, labs, Canvas single-file build (DROPPED 2026-10-22, D12)
- [x] 1.2 Supabase sync, runtime content bundle, Realtime live updates
- [x] 1.3 MCP server (Edge Function `docs-mcp`), tokens, audit log, kill switch, Gemini path token tested
- [x] 1.4 AI space: Review inbox, diffs, risk flags, side panel, undo; Trash with timer (default: keep until deleted by hand)
- [x] 1.5 CI (GitHub Actions) with browser tests; Vercel deploy
- [x] 1.6 Organizations > Projects, roles, invitation links, RLS matrix, project switcher

PHASE 2: Workspace UI v2 (DONE 2026-10-21; polish list below)

- [x] 2.1 Start address = Organizations page (cards/list, search, role filter, sort, create/rename/delete/restore)
- [x] 2.2 Soft delete for organizations (delete_org, restore_org, purge_org; Deleted tab; typed name; Undo)
- [x] 2.3 Organization page: Projects / People / Invitations / Activity / Settings; archived projects restore or delete for good
- [x] 2.4 Invite always reachable (header button, project page, Ctrl+K, Invitations tab)
- [x] 2.5 Project home with all documents and the question bar
- [x] 2.6 Breadcrumbs app > organization > Projects > project > page with switchers
- [x] 2.7 Custom animated dropdowns replace every native select

- [x] 2.8 Compact hover/click areas app-wide (one density rule set)
- [x] 2.9 Sidebar groups (Project, Chapters, Pinned, Questions, Review, Manage); top level lists organizations and projects
- [x] 2.10 Account menu rebuilt (narrow, no search)
- [x] 2.11 One search (Ctrl+K) with scopes, prefixes `>` `#` `@`, recents, finds added pages
- [x] 2.12 Header actions: search, review-inbox bell, pin, "…" menu
- [x] 2.13 Sign-in card on the start page; invitation page asks to sign in first
- [x] 2.14 Invitation email (animated header GIF, CSS animation for Apple Mail/iOS/Samsung, works everywhere, plain-text part) + `/api/invite` + rate limit 20/hour 60/day per organization
- [x] 2.15 Tests for all of the above
- Polish (keep small; research says several of these are low value for a solo owner)
  - [ ] 2.16 S In-app "preview the email" button (sample exists at /email/invite-preview.html); invitation lifetime 72 h; `safeMailDisplayName` for the inviter name in the From display name (strip CR/LF/control characters, quotes, angle brackets; cap length); the message stays fully understandable with images off (headline, inviter, organization, expiry and button are real HTML text; the GIF is decoration; no tracking pixel)
  - [ ] 2.17 S Resend / re-create an invitation from the Invitations tab
  - [ ] 2.18 S Invitee sees pending invitations after sign-in **Q12**
  - [ ] 2.19 S Breadcrumb "…" overflow menu for hidden middle crumbs
  - [ ] 2.20 S Native `<dialog>` + `showModal()` for true modals (top layer, inert background, less home-made code); keep our custom select/menu/combobox (D13); Popover only where it removes light-dismiss code; keep tests for Tab, Escape, Enter, Space, arrows and focus return (docs/19)
  - [ ] 2.20 S Palette: highlight matched letters, recent searches, Ctrl+Enter new tab
  - [ ] 2.21 S Favourites (table user+doc) at the top of lists; recents stay in localStorage (docs/18 #11)
  - [ ] 2.22 S Display name per person (lists show emails today)
  - [ ] 2.23 DEFERRED move project across organizations (export/import covers it)
  - [ ] 2.24 S Transfer ownership; explain "last owner cannot leave" in the UI
  - [ ] 2.25 DEFERRED keyboard chords; 2.27 DEFERRED visual-regression screenshots; 2.28 DEFERRED logos/accents
  - [ ] 2.26 M Phone: bottom bar, test every page at 360 px
  - [ ] 2.29 M Notification inbox (see 3b.2)
- Owner checks (OWN)
  - [?] 2.30 Real two-account invitation test (Invite > link > private window > sign in as that address > Accept)
  - [?] 2.31 Turn on email sending (section 13)

PHASE 3: Private by default and sharing (P5-V) — do before any new table work

D1: only signed-in users see docs; public only through deliberate share links.

- [ ] 3.0 S **Grants rule + 10-30 migration (do first, this week)**: opt in now with `alter default privileges for role postgres in schema public revoke select,insert,update,delete on tables from anon,authenticated,service_role;` + the same for functions (`revoke execute`, also `from public`) and sequences (`revoke usage,select`); every new table AND function gets explicit

GRANT/EXECUTE + RLS + policies + indexes in the same migration; revoke the unneeded anon SELECT on `workbench_state`, `app_admins`, `project_members`; the matrix asserts `has_table_privilege('anon', t, 'select')` and `has_function_privilege('anon', f, 'execute')` are false on private objects. Also: classify the 28 `SECURITY DEFINER` functions (keep / switch to invoker / revoke / move to `private`), set `search_path=''`, qualify `extensions.digest`. Lands before 2026-10-30 (docs/16, docs/19).

- [ ] 3.1 M `get_content_bundle` requires a signed-in member (or a valid share link)
- [ ] 3.2 S Sign-in as the first screen (the start page already shows a card; the spec is still reachable by address until this step)
- [ ] 3.3 M MCP: anonymous tools return nothing; every AI client uses a token
- [ ] 3.4 S Project `geminiforge` set to `private`; check every table, RPC and MCP tool as `anon` (RLS behaviour AND grants)
- [ ] 3.5 M **Share links (audit, docs/21)**: table `share_links` (project-wide per D14; several independent labelled links; read-only; default expiry 7 days, no never-expire; `secret_hash` = SHA-256 of 32 random bytes, raw secret shown once; revoked_at; last_viewed_at; view_count; no raw IP). Redemption through a SERVER proxy (3.11), NOT an anonymous RPC and NOT a share JWT; the SQL function is executable only by service_role and hashes with `extensions.digest`. Public projection allowlist: project name/description; documents (opaque key, title, current body, order); plan (title, hierarchy, status). EXCLUDED: members, emails, user ids, revisions, review inbox, drafts, Trash, comments, tokens, audit, notifications, search tables, Storage, Realtime, exports, restricted documents (Q22). No Storage images in v1 shares
- [ ] 3.6 S Who may make a project public/unlisted: only organization owners/admins **Q1**
- [ ] 3.7 M Tests: anon gets nothing; share link works until revoked or expired; drafts, Trash, exports, search and comments are not readable by outsiders (BookStack lesson, docs/18)
- [ ] 3.8 S RLS rules: `(select auth.uid())`, `to authenticated` on every policy, index every policy column, no `user_metadata`, `security_invoker` views; run advisors after each migration and fail CI on ERROR (docs/16)
- [ ] 3.9 Confirm with the owner before switching (the site stops working for signed-out visitors) **Q3**
- [ ] 3.10 S **Share route** `https://<app>/share#<secret>` (replaces `/#/s/<secret>`): Vercel rewrite `/share` to index.html, hash router also reads `location.pathname`; the first paint shows nothing; an explicit "Open shared project" click POSTs the secret in the body; then `history.replaceState(null,'','/share')`; content stays in memory only (no LocalStorage/IndexedDB/Cache/service worker); no analytics or third-party requests; external links `rel="noopener noreferrer"`; reload after cleanup asks to reopen the link (docs/21)
- [ ] 3.11 M **Share proxy** `api/share.ts` on Vercel (secret key only in a server env var, never `VITE_*`): validate method/Origin/body size/token format, check the global kill switch, rate bucket (pseudonymous, short-lived, no raw IP), then hash + lookup + projection; generic denial text; `Cache-Control: no-store`; revocation checked on every fetch; counters only (view_count, last_viewed_at)
- [ ] 3.12 S **Kill switch** table `private.security_settings(public_sharing_enabled, invitation_sending_enabled)` + owner-only AAL2 actions "disable public sharing" and "revoke all share links"; tested before sharing ships
- [ ] 3.13 M **Invite-bound account creation** (the app has no way to create an account today): public sign-up OFF in the dashboard; `#/join/<token>` GET does nothing; existing account must sign in first; new account: password (minimum 15) + Cloudflare Turnstile + click "Create account and join" POSTs to `api/join`, which validates the invite and calls `auth.admin.createUser(email_confirm:true)` with a server key, inserts membership, consumes the invite, handles partial failure (reconcile record), returns generic errors, never logs

bodies. Note: password-reset mail still uses Supabase's default SMTP (best-effort, rate limited): decide Gmail custom SMTP in Supabase Auth (Q25)

- [ ] 3.14 S **TOTP for owner/admin** (Q23) and `aal2` checked INSIDE the sensitive RPCs and policies (share create/revoke, role changes, export, delete project/user, invite send, kill switch); enrol a BACKUP factor and rehearse recovery on a throwaway account before enforcing; Supabase does not return recovery codes for its own accounts (project-user recovery codes UNVERIFIED)
- [ ] 3.15 S **Harden** `api/invite`: authenticated + AAL2 + org owner/admin checked server-side + an existing unexpired invite row; recipient, subject and body derived server-side (never from the request); quotas 3/hour and 10/day per organization and 3/day per recipient (policy choice, replaces 20/60); generic failure text, no SMTP diagnostics to the browser
- [ ] 3.16 S **Privacy**: delete the duplicate invitee email once the invite is accepted/expired and reconciled (a hash is still personal data); invitation preview shows nothing to unauthenticated visitors; members see names and roles, emails only where needed; deleting a user pseudonymises author ids in revisions instead of cascading; finite retention for security events
- [ ] 3.17 M `private.security_audit_log` append-only (no grants to API roles; trigger rejects UPDATE/DELETE; typed insert helper with a metadata allowlist): role/membership changes, invite create/accept/revoke, share create/revoke/redeem/denial thresholds, export, destructive actions, AAL2 denials, kill-switch use. Never log passwords, raw tokens, secret keys, bodies, headers, raw IPs. Tamper-resistant, not DBA-proof; hash chain only if it becomes important; pgaudit only for investigations. Reuse `membership_events`/`token_events` where they already fit
- [ ] 3.18 S **Incident runbook** (docs, before sharing ships): credential inventory and where each is used; rotation for `sb_secret_`, Gmail app password, Vercel env; leaked share link / key / member account / GitHub / Vercel / Supabase / Google; order for a leaked secret: revoke, rotate, redeploy, inspect, clean history last
- Research: docs/16 (limits, grants), docs/18 (share-link ideas; leak case studies there are UNVERIFIED), docs/21 (audit of the ChatGPT security report)

PHASE 3b: Trust and health (new, from the benchmark)

- [ ] 3b.1 M **Verified pages**: owner_id, verified_by, verified_at, verified_until, review_every_days, reviewed_rev; badge, filter, "changed since verified" diff; an AI-accepted edit does NOT renew the review; **AUDIT CHANGE (docs/19)**: store verification as immutable events `doc_verifications(doc_id, rev, verified_by, verified_at, review_after, note)` tied to our `doc_revisions.rev` and derive the state (unverified / changed since verified / review due / verified), no mutable flag; any later edit flips to "changed since verified"; no bare "still accurate" button (docs/13, docs/18 #1)
- [ ] 3b.2 M **Notifications** table (AI edit waiting, verification due, mention, role change, request access) over Realtime; the bell shows it; no email digest (Q10)
- [ ] 3b.3 S Daily job (pg_cron) only inserts reminder notifications (expiry is derived from `review_after < current_date`, never flipped) (max 8 jobs, each under 10 minutes)
- [ ] 3b.4 S **Request access** button + a `restricted` boolean per document (editors/managers only) instead of full per-page permissions **Decision D15:** a project-wide share shows every non-restricted document; restricted documents never appear in shares
- [ ] 3b.5 S Page views: `doc_view_daily(doc_id, day, count)` upsert RPC (no per-view rows); 30-day views, last viewed, "unread 90 days" staleness signal
- [ ] 3b.6 S In-app link check on save (`doc_links`: broken links, orphans, duplicate titles); markdownlint warnings only (MD001, MD024, MD051-053)
- [ ] 3b.7 S lychee on exported Markdown in CI on a schedule (not every push)

- [ ] 3b.8 S `revisions.actor_kind` (human | ai-token | import) with the token name; keep last N revisions plus every verified one; optional reason on delete
- [ ] 3b.9 S Content-gap list: log every question with no verbatim quote found, with a count; top ten on the dashboard (after phase 7)

PHASE 4: Core product: master file, phases, steps, decisions (design in docs/13)

- [ ] 4.1 M Tables `plan_nodes` (adjacency list `parent_id`, `kind` phase|step, depth ≤ 4, fractional `position` text COLLATE "C", status todo|doing|done|blocked|cancelled|deferred, weight int default 1, rev, `on delete restrict`), `plan_edges` (blocked_by, cycle-rejecting trigger), `decisions` (MADR fields, never renumbered), `decision_links`; RLS inherits from `project_id` via our existing `private.can_read_project/can_edit_project`; GRANTs in the same migration (3.0). **AUDIT CHANGE (docs/19, Q20)**: prefer integer gap `order_key` (our `docs.position` is already integer) over fractional text (keep `COLLATE "C"` only if fractional stays); drop weights in v1 (equal leaf steps); do not put a plain unique index on the order key (reorders hit transient duplicates: deferrable constraint or two-step renumber); depth trigger as in the report
- [ ] 4.2 M Progress as a SQL view/RPC, never stored: only leaf steps count; cancelled/deferred leave the denominator; blocked stays and shows a red count with its reason; `doing` counts 0 (optional 25% toggle); empty container shows "no steps"; round down so 99.6% never shows 100%; show n/m, "+N steps added" (baseline when a phase starts), next step
- [ ] 4.3 M Master file view: auto-index of phases with progress; phase view with steps/sub-steps and check marks; dependencies ("waiting on D-0012")
- [ ] 4.4 M Decision log (MADR 4.0): proposed > accepted > deprecated | superseded | rejected; accepted records change only status and supersession; `[[D-0012]]` links; accepting offers to unblock linked steps; `review-by` feeds the stale list
- [ ] 4.5 S Templates: software, research, course, trip, "this master plan" (import via status-character map `x` done, ~ doing, `?` blocked "waiting on owner"); `is_template` flag + "New from template" copy, no variables yet
- [ ] 4.6 S List view only first; board, timeline and ICS DEFERRED
- [ ] 4.7 S Project dashboard: open steps, blocked steps, waiting AI edits, stale pages, content gaps
- [ ] 4.8 M AI proposals never write plan tables: ops `{set_status|move|insert|retitle|edit_notes, node_id, base_rev, value}` go to the Review inbox; accept only if `rev = base_rev` (else stale); AI creates decisions only as `proposed`; check marks are never auto-applied; moves validated for cycles and depth
- [ ] 4.9 S Q9 decide whether this master plan becomes the first project (template)

PHASE 5: Editor: owner edits everything (docs/17)

- [ ] 5.1 M **CodeMirror 6** Markdown editor with `react-markdown` preview (split or toggle); front matter via `remark-frontmatter`; math (KaTeX) and Mermaid lazy-loaded; sanitize after the last unsafe step; rules (docs/19): no raw HTML, never `dangerouslySetInnerHTML`, URL scheme allowlist, no remote images in the Review inbox, render search snippets as text with our own `<mark>`, Mermaid DEFERRED, KaTeX only after a sanitizer test; fix-up for `user-content-` id prefix in block anchors
- [ ] 5.2 M Save with a `version` column (`update … where version = base`); on conflict 3-way merge (`node-diff3`), remaining conflicts shown as a diff; keep BOTH versions on conflict; Supabase Presence only for a soft "X is editing" banner; no offline writes in v1

- [ ] 5.3 L Edit generated spec pages and chapters; migrate derived spec documents to native documents (docs/01 step 6)
- [ ] 5.4 M Add / remove / move / rename chapters and sections; drag-and-drop order (fractional keys)
- [ ] 5.5 M Revision compare of any two versions (`diff` jsdiff 9); restore one paragraph
- [ ] 5.6 M Internal links `[[kind:slug]]` (small micromark/remark plugin, keyed on ids), backlinks panel
- [ ] 5.7 M Per-hunk accept in the Review inbox with `@codemirror/merge` (`unifiedMergeView`, `acceptChunk`/`rejectChunk`); human "suggest" edits from viewers also go through the inbox; comments carry an anchor quote + resolved flag, no threads yet
- [ ] 5.8 M Import/export (docs/21): Markdown zip in and out FIRST, parsed in a Worker (`@zip.js/zip.js` 2.24.0 preferred for hostile input, fflate 0.8.3 acceptable, version pinned) with hard caps (25 MiB archive, 100 MiB emitted bytes counted while decompressing, 10 MiB per entry, 1000 entries, ratio 100:1, depth 20, filename 240) and rejection of symlinks, absolute/drive/UNC paths, `..`, NUL, Windows reserved names, case/normalisation collisions, nested archives; front matter: known scalar keys only, no custom tags/aliases, reject `__proto__`/`constructor`/`prototype`; CSV export neutralises `= + - @`; SVG upload rejected; EXIF/GPS stripped by re-encoding if images ever import. DEFERRED: `.docx` (when added: Mammoth latest, Worker, external file access off, advisories rechecked), Notion zip, Obsidian vaults (ignore `.obsidian`). Test corpus = M01-M37 in docs/21a; keep zip export working at all times
- [ ] 5.9 S Images only (Supabase 1 GB bucket, 50 MB file cap); other attachments DEFERRED
- [ ] 5.10 DEFERRED Tiptap block editor (ship later behind a round-trip gate: parse > serialize > compare, else source mode), inline live-preview decorations, CRDT (Yjs/Hocuspocus/Liveblocks/Automerge), Mermaid sandbox, PDF export (use print CSS)

PHASE 6: AI space v2 and token safety (docs/14) — re-ordered

- [ ] 6.1 S **Verify the MCP with Claude Code, Cursor, claude.ai connectors and the Gemini app FIRST** (only Gemini is tested today) **Q5**; then make `header` the default token kind and `path` the exception
- [ ] 6.2 S **Sanitise the Review inbox**: no remote images, link targets shown as text, diffs as plain text (exfiltration through rendering; Notion AI lesson)
- [ ] 6.3 S Token format `gfk_…` + CRC32 base62 checksum, last 4 characters shown, gitleaks rule in CI
- [ ] 6.4 M Two token kinds, path tokens read-only with 24 h default expiry, one per client, revoked on rotation; rotation with overlap
- [ ] 6.5 M Per-token tool and document allow-lists; static tool descriptions; expose a hash of the tool list; token templates (Reader, Typo fixer, Writer)
- [ ] 6.6 S Per-token usage panel (last used, call count, documents touched, from the audit log); MCP tool `report_issue(doc, text)` lands in the Review inbox
- [ ] 6.7 M Review friction: a reason is required to accept high-risk drafts, no bulk accept for them; auto-accept only a narrow class (typo fixes by a named token template), off by default
- [ ] 6.8 M Data protection: purge or hash invitee email after accept/expiry, per-person export and delete, log retention period, no tokens or IPs in logs
- [ ] 6.9 S Append-only audit log + CSV export; weekly head hash emailed to an external mailbox (anchoring) — hash chain/replay DEFERRED
- [ ] 6.10 S Keep the kill switch and per-token limits; anomaly alerts and auto-pause only if cheap
- [ ] 6.11 M OAuth stage ONLY if 6.1 shows a client needs it: Supabase OAuth 2.1 server is a public beta with full-privilege user tokens; needs DCR enabled, a consent page (client name, exact redirect URI, CSRF, anti-

framing), RESTRICTIVE RLS for `client_id IS NOT NULL`, an access-token hook setting/checking `aud`, 401 + `resource_metadata` from the Edge Function, manual tokens kept as fallback

- [ ] 6.12 L Support MCP spec 2026-07-28 (stateless, `server/discover`, `ttlMs`) once the clients you use adopt it
- [ ] 6.13 S Per-project retention of activity and AI policy
- DEFERRED: two-person approval; GitHub secret-scanning partner programme

PHASE 7: Ask-the-docs at zero cost (docs/15, constraint D11)

- [ ] 7.1 S **Free path 1: Gemini app + our MCP.** Add our read-only MCP as a custom app in the Gemini app (works with your AI Pro account; US, English, personal Google account per Google's help page; confirm exact requirements with prompt R15). Ask questions there; our server only returns documents (no key, no cost). Edits still go through the Review inbox.
- [ ] 7.2 S **Free path 2: NotebookLM ("Gemini Notebook")** as a personal reading aid: free 50 sources per notebook; merge pages into ≤ 50 files (export from the app). It cannot be called from our app.
- [ ] 7.3 M **Extractive quote-finder (no model):** chunks by heading (h2/h3, ≤ 600 tokens, offsets stored) + Postgres FTS (generated tsvector, GIN, `websearch_to_tsquery`, heading weight A); the answer is the best passages shown verbatim with a link to the heading. Always verbatim by construction; no API, no key, no cost.
- [ ] 7.4 S Content-gap log: every question with no passage found, with a count (feeds the dashboard)
- [ ] 7.5 M 40-question golden set (24 single-page incl. 8 exact strings, 6 two-page, 4 paraphrases, 6 unanswerable, 2 injection) + metrics (recall@6, correct refusals 6/6, false refusals ≤ 10%); re-run after every retrieval change
- [ ] 7.6 S Trust boost: verified pages rank higher; mark results verified/unverified
- [ ] 7.7 DECISION via prompt **Z1**: optional generative answers at 0 cost: (a) in-browser model (WebGPU; private; quality and size unknown), (b) Gemini API free tier (limits unpublished, free-tier prompts may be used to improve Google products: only for non-private text or with your explicit consent), (c) OpenRouter `:free` models on ONE account (50 requests/day; some may train on inputs), (d) Cloudflare Workers AI free 10,000 neurons/day (terms unchecked). If any is chosen, keep: quote-then-verify substring check (NFC + whitespace/quote/dash normalisation, quote must be a contiguous substring of a retrieved chunk, 6-80 words, display text from our DB), no tools, plain-text rendering, per-user and global daily caps, key only as an Edge Function secret.
- NOT used (costs money or breaks terms): Anthropic/OpenAI/paid Gemini, rotating several free accounts.

PHASE 8: Reader and search

- [ ] 8.1 M Stable block anchors + copy link; search filter chips (project, kind, verified, owner, labels); keyword search only until the 40-question set fails
- [ ] 8.2 S Reading position memory, changed-since-I-read markers
- [ ] 8.3 M Offline READ cache only: vite-plugin-pwa precaches the app shell; allow-listed pinned documents in IndexedDB (Dexie); on sign-out delete IndexedDB, caches and the service worker; do not cache API responses; test Safari's 7-day rule on your phone
- [ ] 8.4 DEFERRED semantic search, listen, focus mode, split view
- [ ] 8.5 S Single-key shortcut toggle (WCAG 2.1.4), contrast controls

PHASE 9: Operations, quality, survival (docs/16)

- [x] 9.1 CI runs typecheck, build, browser suites, MCP offline tests
- [ ] 9.2 S **Keep-alive (docs/22)**: migration `public.ops_keepalive` (one row, explicit `GRANT SELECT` to anon/authenticated, RLS policy `id = 1`, no writes, not in the Realtime publication); two independent daily readers through PostgREST: Vercel cron `/api/ops-keepalive` (Hobby: once a day, runs anywhere inside the hour, +-59 min) and a GitHub Actions schedule at another hour (public-repo schedules self-disable after 60 days without repo activity). Reuse the env lookups `api/invite.ts` already uses. Each pings its own Healthchecks check on success and `/fail` on error (grace at least 2 h). Reading through PostgREST is the best-supported way to count as "user database activity"; `pg_cron`/Auth-only/no-DB calls are NOT relied on. Route the Supabase pause-warning email to a mailbox you read. Restore window after a pause is 1 year (live page; the MCP docs index still says 90 days)
- [ ] 9.3 M **Backups (rewritten 2026-10-22, audited docs/22)**: Free has no managed backups (verified). Nightly Actions job: `supabase/setup-cli` (pinned SHA + pinned CLI version, no global npm install, no checkout), `SUPABASE_DB_URL` = **session pooler** string (the direct host is IPv6 only), three dumps (`--role-only`, schema, `--use-copy --data-only`), fail if empty, a manifest of row counts, **restore into a Supabase-shaped target in the same job** (local `supabase start` or vanilla Postgres 17 plus a prelude for roles anon/authenticated/service_role, schema auth and extensions; plain `postgres:17` alone fails; choose after inspecting the first real dump) with `psql --single-transaction -v ON_ERROR_STOP=1` and `session_replication_role = replica`; then `age` encrypt to the PUBLIC recipient (repo variable; private identity offline in two physical copies, never in GitHub); upload ciphertext only (artifact retention 14 d) and copy ciphertext to Backblaze B2 (10 GB free; rclone from the distro package, not `curl | bash`; app key limited to one bucket; Environment secrets limited to `main`); ping Healthchecks (`/start`, success, `/fail`). One daily cron; the weekly drill is decided inside the job by weekday (the report's `github.event.schedule == ...` test never fires). Separate Storage exporter with SHA-256 manifest, encrypted too. Monthly: owner downloads one object from B2, decrypts offline, restores locally. Exports are not one atomic snapshot (accepted). Nothing unencrypted is ever uploaded (public repo, D17)
- [ ] 9.4 S **Headers (docs/21)**: first move the inline CSS string (`parts/20-styles.tsx`) and the `<style>` in index.html into a real Vite CSS file; remove Google Fonts (system stack or self-hosted); then `vercel.json`: rewrite `/share`; CSP first as `Content-Security-Policy-Report-Only` (default-src 'none'; script-src 'self'; style-src 'self'; img-src 'self' blob: + our Supabase host; font-src 'self'; connect-src 'self' + Supabase https and wss; worker-src 'self' (add blob: only if the ZIP worker needs it); frame-src/media-src/object-src 'none'; base-uri 'none'; form-action 'self'; frame-ancestors 'none'; Trusted Types report-only later), global `Referrer-Policy: no-referrer`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Permissions-Policy` (camera/microphone/geolocation/payment/usb off), `Cross-Origin-Opener-Policy`/`Cross-Origin-Resource-Policy: same-origin`, global `X-Robots-Tag: noindex, nofollow, noarchive`, `/share` `Cache-Control: no-store`, `/assets/*` immutable one year. Do NOT set HSTS (Vercel already sends `max-age=63072000; includeSubDomains; preload`). No public CSP-report endpoint in v1 (catch violations in Playwright); enforce after the browser suite is clean. Vercel Hobby protects only preview/deployment URLs, not production (docs; a report claiming otherwise is unconfirmed)
- [ ] 9.5 S **CI and supply chain (docs/21)**: `permissions: contents: read`; every third-party action pinned by full commit SHA; never `pull_request_target` with untrusted code; no production secrets in PR jobs or in the dependency-install/build step; gitleaks (custom rules for `sb_secret_`, `GMAIL_APP_PASSWORD`, legacy service key) + osv-scanner + `npm audit --omit=dev --audit-level=high`; `npm ci` always; Dependabot (npm + github-actions, weekly, with cooldown, no auto-merge); npm `min-release-age=7` (npm >= 11.10); try `npm ci --ignore-scripts` and list which packages need scripts; GitHub settings: secret scanning + push protection, Dependabot alerts/updates, code scanning (check availability on a free account), private vulnerability reporting, a ruleset requiring CI on `main`; full-history secret scan DONE 2026-10-22 (53

commits clean); root accounts (GitHub, Vercel, Supabase, Google): unique password, strongest MFA offered, offline recovery material, few tokens; Playwright artifacts 7 days, traces only on failure

- [ ] 9.6 S Edge Function + migrations deployed from CI (scoped token, `supabase/setup-cli`, `db push --dry-run` first)
- [ ] 9.7 M pgTAP (`supabase test db`) next to the live DO-block matrix; axe in CI via @axe-core/playwright (wcag2a/aa, 21a/aa)
- [ ] 9.8 S **Monitoring (docs/22)**: UptimeRobot Free (50 monitors, 5 min; site + `/api/health`, which reads one row) and Healthchecks.io Hobbyist (20 checks: keep-alive x2, backup, storage export, restore drill, mail smoke test); alerts go to a personal address, not through the app's own mail; errors logged to a small table (Vercel runtime logs last 1 hour on Hobby). Keep both on separate free accounts, one purpose each (Healthchecks forbids multiple accounts to dodge limits)
- [ ] 9.9 S Legacy keys: browser, invite function and MCP already use `sb_publishable_`/`sb_secret_` (MCP still falls back to the legacy variable). Remaining: confirm in the dashboard, disable the legacy keys, remove the fallback, check `pg_net`/webhooks (secret key in the `apikey` header), audit Auth JWT signing keys (not the same project as API keys)
- [ ] 9.10 S Hobby is non-commercial: no payments/ads/paid hosting (check phase 11 ideas). No paid plans (D11): pausing is handled by 9.2, backups by 9.3; if a free tier is ever withdrawn, plan the export-and-move (Markdown zip + SQL dump) instead of paying
- [ ] 9.11 S Code-split the app (500 kB+ bundle warning), lazy-load labs and the answer engine
- [ ] 9.12 S **Canvas single-file build dropped (D12)**: tag the repo, then delete `canvas/`, `build-final.mjs`, `vite.final.config.ts`, `final/`, `index.final.html`, `App.final.tsx`, `main.final.tsx` and the Canvas tests
- [ ] 9.14 S React 19.3.1 (18.3.1 already in use as the stepping stone) + Vite 8.3.5; full Playwright suite green; NO React Compiler in the same change; View Transitions optional later
- [ ] 9.15 S **Exit drill (docs/22)**: quarterly, restore the newest decrypted backup into a throwaway Neon Free project (1 GB per project, no card) and open the Markdown export. No $0 drop-in Supabase replacement exists (Auth, PostgREST, Realtime and Storage would have to be rebuilt); Neon is database-only. Netlify/Cloudflare Pages stay documented static-hosting exits, not set up
- [ ] 9.13 DEFERRED restructure R0 (folder layout) after features settle. Domain + Resend DROPPED (costs money): email stays on the free Gmail path

PHASE 10: Content corrections (after the app is finished, per owner)

- [ ] 10.1 Decide claims A1-A13 in docs/claims_ledger.md (or "apply all suggested actions")
- [ ] 10.2 Re-audit the GeminiForge documents; separate Gemini deep-research runs for that (not in docs/12)

PHASE 11: Optional (docs/05, pick later; each needs its own research; Hobby is non-commercial)

12. Cut or deferred (and why)

Two-person approval; hash-chain/replay audit; OAuth server (unless 6.1 proves a client needs it); pgvector; board/timeline/ICS; non-image attachments; move project across organizations; keyboard chords; visual-regression screenshots; logos/accents; domain + Resend; listen/focus/split view; four importers at once; backup encryption; CRDT; Tiptap block editor; offline writes; Notion link-graph reconstruction; PDF export; GitHub secret-scanning

partner programme. Reasons: a solo owner on free tiers; most of these are Enterprise-tier features elsewhere (docs/18).

13. Turn on invitation email (OWN, about 5 minutes)

The website cannot send mail by itself. Supabase's built-in mail reaches only your own team's addresses (2 per hour); Resend's test sender reaches only your own address (docs/10, docs/16). `/api/invite` is deployed and already creates invitations; it emails as soon as it finds two settings.

1. Use a dedicated Gmail account; turn on 2-Step Verification. 2. Create an **app password** (Google Account > Security > App passwords; 16 letters). 3. Vercel dashboard > geminiforge-workbench > Settings > Environment Variables: `GMAIL_USER`, `GMAIL_APP_PASSWORD` (Production, sensitive); redeploy. 4. Open an organization > Invite; the checkbox "Email the invitation now" turns on. Never paste the password into chat or code. Limits: the app allows 3/hour and 10/day per organization and 3/day per recipient (policy, not Google limits; Google's exact personal-Gmail cap is UNVERIFIED, Workspace is 2,000/day). Gmail app passwords need 2-Step Verification that is NOT security-keys-only, no Advanced Protection, and are revoked when the Google password changes; SMTP `smtp.gmail.com:465` is UNVERIFIED from a Google page, so the first real send is the test. UNTESTED against a real mailbox until you add the settings. Edge Functions block ports 25/587 (465 is simply not documented as blocked), which is why the sender runs on Vercel; Supabase Auth custom SMTP is a separate service configured in the Auth dashboard (D18).

14. Questions for the owner (recommendation first)

- **Q1** Who may make a project public/unlisted? Only organization owners/admins.
- **Q2** May any signed-in user create an organization? No, only you for now.
- **Q3** When do we switch to "only signed-in users see docs"? Right after the first real two-account invitation test; note 3.0 (grants) lands before 2026-10-30 regardless.
- **Q4 (resolved, D12)** Canvas single-file build dropped.
- **Q5** Which AI clients besides Gemini matter (Claude Code, Cursor, claude.ai, ChatGPT)? This decides token kinds and OAuth (6.1).
- **Q6** Dark only? Yes (earlier decision).
- **Q7** Email: Gmail app password (free). A domain is out because of the $0 rule.
- **Q8 (resolved by research)** No key rotation. Q14 below replaces it.
- **Q9** Should this master plan become the first project in the app?
- **Q10** Notifications only inside the app (recommended) or also a daily email?
- **Q11 (recommend: skip)** Moving a project across organizations.
- **Q12** Show people their pending invitations after sign-in? Yes.
- **Q13** What does "Argon High" in your Gemini app refer to? Send a screenshot of the picker.
- **Q14 (replaced)** Ask-the-docs at $0: OK to start with Gemini app + MCP, NotebookLM and the extractive quote-finder, and decide generative answers after prompt Z1?
- **Q15** Turn on TOTP two-factor sign-in for your login (free per the docs, confirm in the dashboard)?
- **Q16** OK to add a daily keep-alive ping so the free project does not pause? (Supabase states no policy against it; paid plans are out.)
- **Q17** Do you want "verified pages" (owner + review date + badge)? Recommended: yes, it is the most valuable gap found.
- **Q18** Is a Markdown source editor with preview acceptable (not WYSIWYG)? Recommended; a block editor can come later.

- **Q20** Planning order key: integer gaps and equal-weight steps (recommended by the audit) instead of fractional text and weights?
- **Q21** Minimum browser baseline: current and previous major of Chrome, Edge, Firefox, Safari incl. iOS (recommended; makes the native-dialog/CSS plan simple)?
- **Q22 (resolved, D15)** A project share shows every NON-restricted document and the share dialog says so.
- **Q23 (resolved, D16)** TOTP is mandatory for the owner, organization admins and project managers; everyone else is encouraged.
- **Q24 (resolved, D17)** The repo stays public while that helps; gitleaks runs in CI either way. Consequence: anything a workflow uploads (artifacts, logs) is downloadable by any signed-in GitHub user for 90 days by default, so NEVER upload unencrypted backups or data there.
- **Q25 (resolved, D18)** Gmail becomes Supabase Auth custom SMTP so password-reset mail is reliable (Supabase's custom-SMTP default is 30 new users/hour; `smtp.gmail.com:465` is UNVERIFIED from a Google page: prove it with one real send in a Preview, docs/22).
- **Q19 (replaced by Q27/Q28)** Backups: unencrypted private-repo artifacts are OUT (repo is public). Encrypted with `age` and copied to Backblaze B2.
- **Q26** Create a NEW dedicated Gmail for sending (authenticator-app or phone 2-Step Verification, NOT security-keys-only, no Advanced Protection; recovery info you control)? Recommended: yes (docs/22).
- **Q27** Try the Backblaze B2 sign-up now (email + probably a phone number; tell me if it asks for a card)? If it needs a card, fallback = 14-day encrypted artifact + a monthly manual download to your PC.
- **Q28** Keep two offline copies of the `age` private key (for example USB stick + paper, in different places)? Recommended: yes; without it every backup is unreadable.
- **Q29** Free Healthchecks.io and UptimeRobot accounts, one each, using the dedicated Gmail? Recommended: yes.

15. Decisions already made (do not re-ask)

D1 only signed-in users see docs, public only via share links. D2 **ENGLISH ONLY, ALWAYS** (UI, documents, prompts, research; owner said this repeatedly). D3 invited-only access: members see only invited projects; org owners/admins see all. D4 Trash default: keep until deleted by hand, timer per project. D5 multiple projects are a main feature; everything editable. D6 content corrections after the app is finished. D7 secrets never in chat/code/git; keys enter through dashboards. D8 free Supabase plan (no leaked-password protection). D9 daily research task deleted. D10 start address opens the Organizations page. **D11 (2026-10-21) spend nothing: free tiers only, no paid plans, APIs, domains or credits. D12 (2026-10-22) the Canvas single-file build is dropped. D13 (2026-10-22) keep our custom animated dropdowns (not native select). D14 (2026-10-22) share links are project-wide (read-only, expiring, revocable). D15** a project share shows all non-restricted documents. **D16** TOTP mandatory for owner, org admins, project managers. **D17** repo stays public (history clean; no unencrypted data in workflow artifacts). **D18** Gmail as Supabase Auth custom SMTP.

16. Research map

Done by Claude with sources: docs/10 (UI, email, Gemini, file hand-over), 13 (planning layer, decisions, health), 14 (MCP security, tokens, OAuth, review), 15 (ask-the-docs), 16 (Supabase/Vercel/GitHub limits, ops), 17 (editor, collaboration, offline, Markdown, import/export), 18 (workspace benchmark). Four big Gemini deep-research runs (technical foundations, AI-native docs, feature discovery, UX/visual design): docs/12. Their reports will be merged into this plan as docs/19-RESEARCH-RUN1..4. Also docs/19 (audit of the ChatGPT Parts A+B report, 2026-10-22; raw report docs/19a): corrections and live facts. Also docs/21 (audit of the ChatGPT Part C report, 2026-10-22; raw report docs/21a): verified facts, wrong claims, adopted design. Also docs/22 (audit of the ChatGPT Part E+F

operations/email report, 2026-10-22; raw report docs/22a): verified platform limits, defects in the sample workflows, adopted keep-alive/backup/monitoring/email design. **Research status (2026-10-22):** DONE and audited: A+B (docs/19), C (docs/21), E+F (docs/22). TO DO, prompts ready in docs/23 (ChatGPT Deep Research): Run 5 = parts D+G (accessibility, interaction, offline, performance, testing, engineering quality), Run 6 = AI and MCP (ask-the-docs, review inbox, agent access, safety), Run 7 = feature discovery, Run 8 = UX and visual design. Owner rule: finish all research first, then plan. The Gemini prompts in docs/12 are superseded (Gemini froze at report writing three times).